

ANALYSING DVWA VULNERABILITIES USING BURP SUITE

REPORT BY - MUBASSHERA ZAIDY

INTRODUCTION

DVWA (Damn Vulnerable Web Application)

It is a deliberately insecure PHP/MySQL web app used for practicing penetration testing.

Common vulnerabilities : SQL Injection, XSS, CSRF, File Upload, Command Injection, Brute Force.

BURP SUITE

It is a toolkit for web application penetration testing developed by PortSwigger.

Tools:

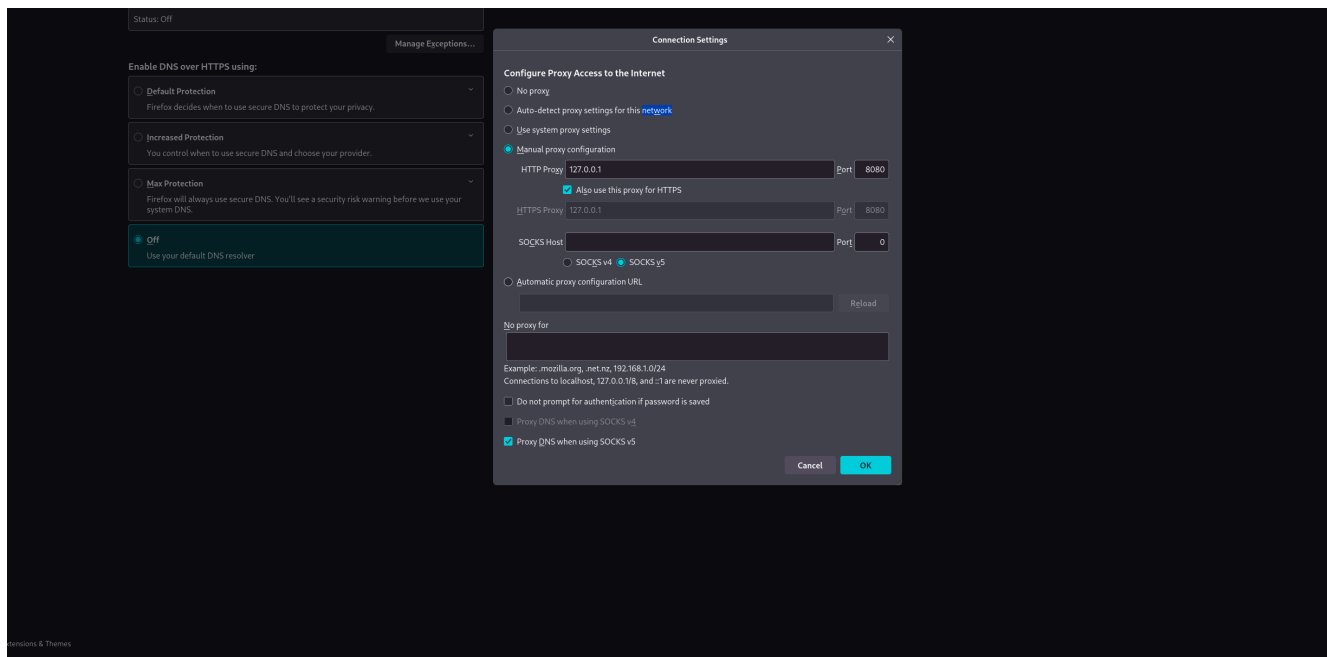
- **Proxy:** Intercepts and modifies HTTP/S requests.
- **Repeater:** Replays and manipulates requests.
- **Intruder:** Automates attacks like brute force.
- **Scanner (Pro edition):** Detects vulnerabilities automatically.

OBJECTIVE

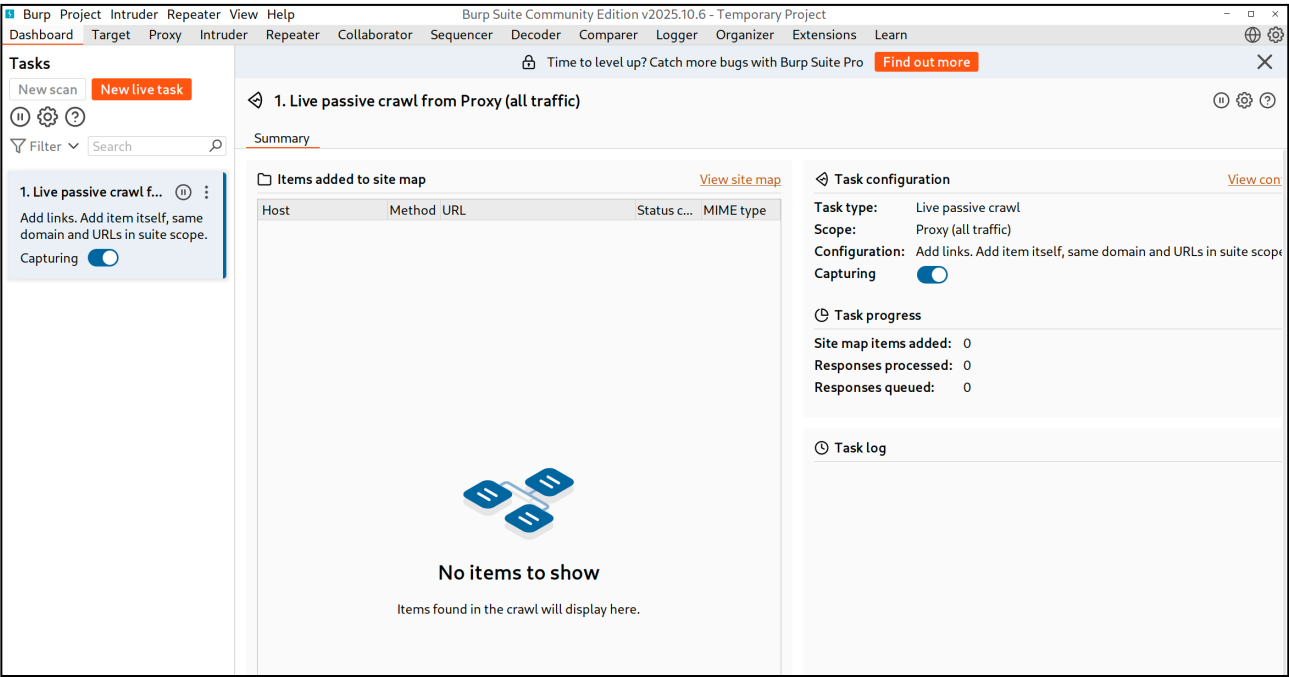
To analyse DVWA Vulnerabilities using Burp Suite

METHODOLOGY

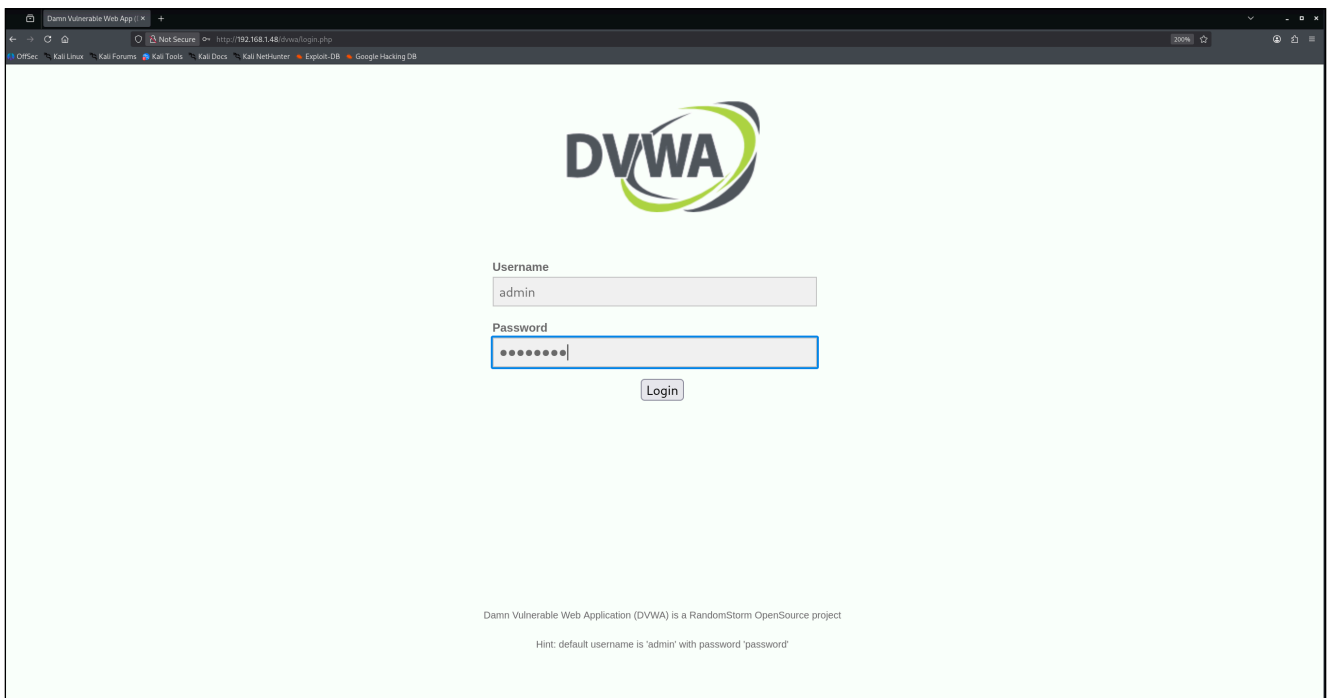
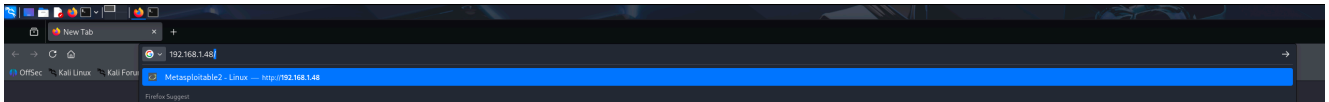
STEP 1: Set your browser proxy to 127.0.0.1:8080.



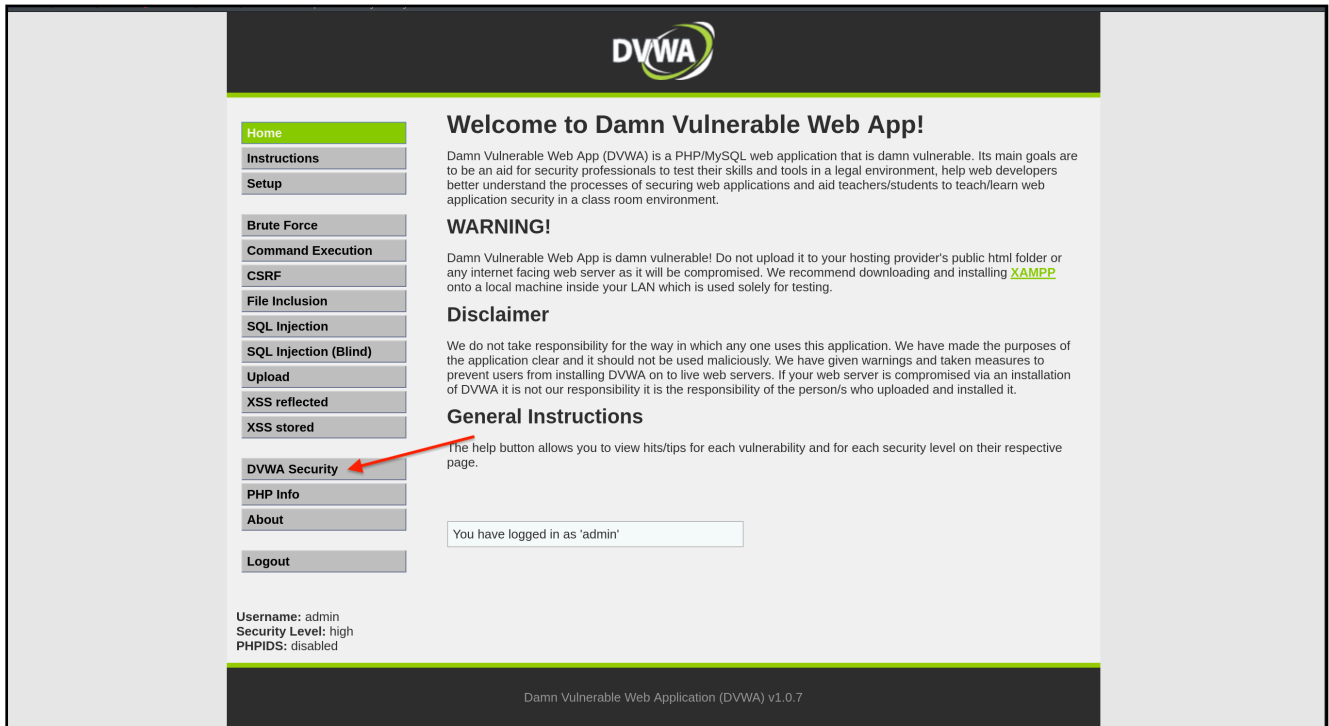
STEP 2 : Start Burpsuite



STEP 3 : Start DVWA by entering your metasploitable IP on your browser. Enter login name 'admin' and password - 'password'



STEP 4 : Click on DVWA Security set it 'low' and submit



DVWA

Welcome to Damn Vulnerable Web App!

Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.

WARNING!

Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing [XAMPP](#) onto a local machine inside your LAN which is used solely for testing.

Disclaimer

We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

General Instructions

The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.

You have logged in as 'admin'

Username: admin
Security Level: high
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7



DVWA

DVWA Security

Script Security

Security Level is currently **high**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low medium high

PHPIDS v0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

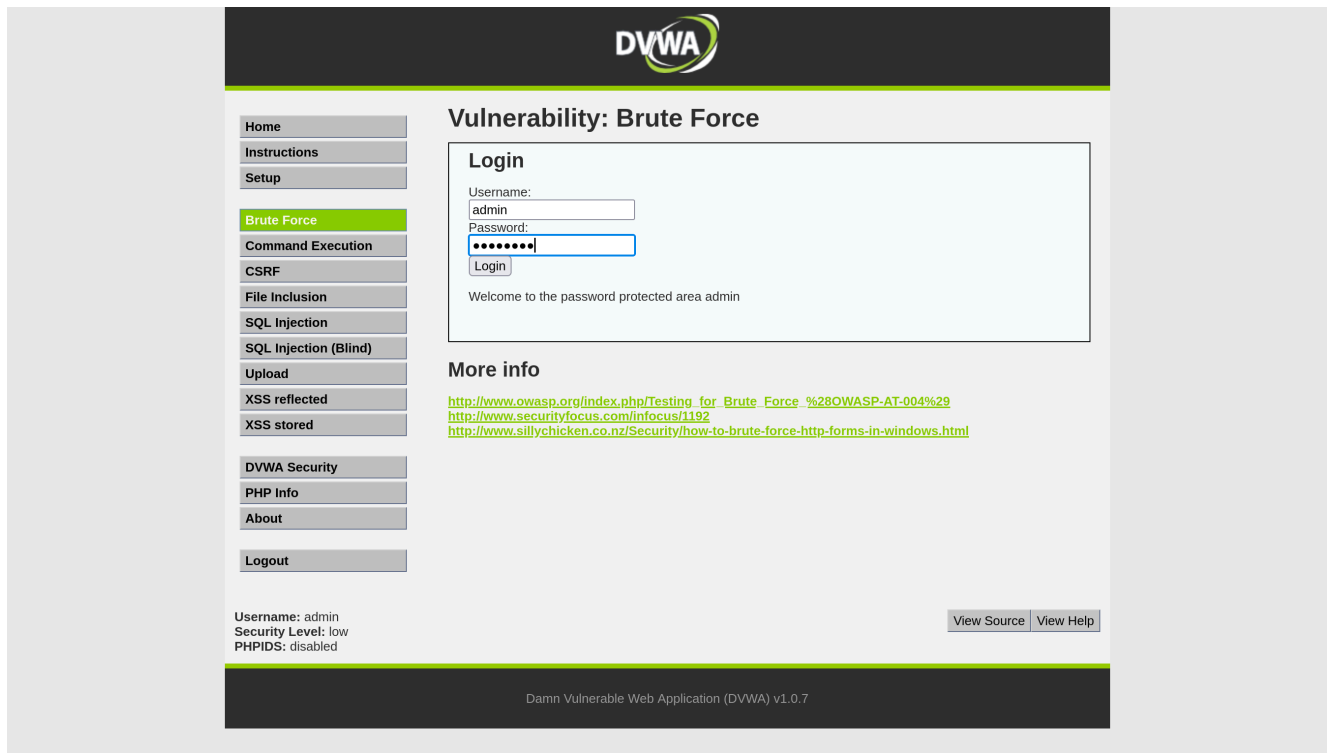
PHPIDS is currently **disabled**. [\[enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Username: admin
Security Level: high
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7

STEP 5 : Next navigate to the Brute Force section.
Under Login enter your username and password i.e admin
and password respectively.



The screenshot displays the DVWA (Damn Vulnerable Web Application) interface. The top header features the DVWA logo. A left-hand navigation menu lists various sections: Home, Instructions, Setup, Brute Force (highlighted in green), Command Execution, CSRF, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, XSS stored, DVWA Security, PHP Info, About, and Logout. The main content area is titled 'Vulnerability: Brute Force' and contains a 'Login' form. The form has two input fields: 'Username' with the value 'admin' and 'Password' with masked characters. A 'Login' button is positioned below the password field. Below the form, a message reads 'Welcome to the password protected area admin'. Under the 'More info' heading, three links are provided: http://www.owasp.org/index.php/Testing_for_Brute_Force_%28OWASP-AT-004%29, <http://www.securityfocus.com/infocus/1192>, and <http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html>. At the bottom left, the current session details are shown: 'Username: admin', 'Security Level: low', and 'PHPIDS: disabled'. At the bottom right, there are 'View Source' and 'View Help' buttons. The footer at the very bottom states 'Damn Vulnerable Web Application (DVWA) v1.0.7'.

Vulnerability: Brute Force

Login

Username:

Password:

Welcome to the password protected area admin

More info

http://www.owasp.org/index.php/Testing_for_Brute_Force_%28OWASP-AT-004%29
<http://www.securityfocus.com/infocus/1192>
<http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html>

Username: admin
Security Level: low
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7

STEP 6 : Now in Burp suite, you'll be able to see the credentials you typed in the brute force section.

The screenshot displays the Burp Suite interface with the Site map on the left, the HTTP history table at the top, and the Request/Response details pane at the bottom. The Site map shows the 'brute' directory under 'vulnerabilities'. The HTTP history table lists a GET request to `/dvwa/vulnerabilities/brute/?username=admin&password=admin&login=Login HTTP/1.1` with a status of 200. The Request pane shows the raw HTTP request, and the Response pane shows the raw HTML response, which includes a login form and a message indicating a password-protected area.

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time
192.168.1.48	GET	/dvwa/vulnerabilities/brute/?username=admin&password=admin&login=Login HTTP/1.1		200	4986	HTML	Damn Vulnerable Web App (DV...		23:34

Request

```
GET /dvwa/vulnerabilities/brute/?username=admin&password=admin&login=Login HTTP/1.1
Host: 192.168.1.48
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://192.168.1.48/dvwa/vulnerabilities/brute/
Cookie: security=lay; PHPSESSID=180095462565772046256219114
Upgrade-Insecure-Requests: 1
Priority: u=0, i

```

Response

```

<div class="body_padded">
  <div>
    Vulnerability: Brute Force
  </div>
  <div class="vulnerable_code_area">
    <div>
      Login
    </div>
    <form action="#" method="GET">
      Username:<div>
        <input type="text" name="username">
      </div>
      Password:<div>
        <input type="password" value="admin">
      </div>
      <input type="submit" value="Login" name="login">
    </form>
  </div>
  <div>
    to the password protected area admin
  </div>
  <div>
    
  </div>
  <div>
    More info
  </div>
  <div>
    <div>
      <a href="http://hiderefer.com/http://www.owasp.org/index.php/Testing_for_Brute_Force_HTTP_A209" target="_blank">
        http://www.owasp.org/index.php/Testing_for_Brute_Force_HTTP_A209
      </a>
    </div>
    <div>
      <a href="http://hiderefer.com/http://www.securityfocus.com/infocus/1392" target="_blank">
        http://www.securityfocus.com/infocus/1392
      </a>
    </div>
    <div>
      <a href="http://hiderefer.com/http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html" target="_blank">
        http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html
      </a>
    </div>
  </div>
</div>

```

RESULT

The Burp Suite analysis of DVWA's Brute Force module successfully captured and displayed the login request and response. By intercepting the credential submission, it was observed that the application accepts repeated login attempts without restriction. This confirms the vulnerability to brute force attacks, fulfilling the aim of analyzing DVWA vulnerabilities using Burp Suite.